

Security+ 2.1 · Threat Actors

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.1 — Threat Actors (10:23) · [vídeo original](#)
[↗](#) · [YouTube](#) [↗](#)

Quem ataca e POR QUÊ: nation-state (governo — espionagem/sabotagem, recursos enorme — APT); organized crime (lucro — ransomware, credential theft); hacktivist (ideologia — Anonymous); insider (dentro da casa — intencional ou descuidado); script kiddie (usa exploit pronto, volume); shadow IT (aplicação não-oficial que vira porta de entrada); competidor (industrial espionage).

Highlights que a prova cobra

- APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo
- Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar
- Script kiddie: usa exploit pronto — volume, pouca sofisticação
- Insider: o maior risco por já estar DENTRO da confiança

Dicas de prova

- 'motivated by political/social ideology' = hacktivist
- 'long-term, nation-state, persistent' = APT

Cenário clássico: Cenário típico: 'um grupo financiado por governo espiona infra-critical por meses' = APT (nation-state) — não hacktivist nem criminal.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?

- A)** BEC / CEO fraud (fraude do CEO)
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?

- A)** Firewall mal configurado
- B)** Phishing + VPN sem MFA / credencial vazada
- C)** Cabo de rede exposto
- D)** Falta de antivírus

3. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

4. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: APT (Advanced Persistent Threat): government-backed — recursos enormes, tar...

5. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Organized crime = dinheiro; hacktivist = ideologia; nation-state = política...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Script kiddie: usa exploit pronto — volume, pouca sofisticação'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Script kiddie: usa exploit pronto — volume, pouca sofisticação...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Insider: o maior risco por já estar DENTRO da confiança'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Insider: o maior risco por já estar DENTRO da confiança...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: "motivated by political/social ideology" = hacktivist'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'motivated by political/social ideology' = hacktivist...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: "long-term, nation-state, persistent" = APT'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'long-term, nation-state, persistent' = APT...

10. Cenário corporativo (Threat Actors): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.1), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'um grupo financiado por governo espiona infra-critical por meses' = APT (nation-state) — não hacktivist nem criminal.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário típico: 'um grupo financiado por governo espiona infra-critical por...

GABARITO COMENTADO

1) A — BEC / CEO fraud (fraude do CEO). BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados.

Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima)

2) B — Phishing + VPN sem MFA / credencial vazada. A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1.

3) B — Identificar, Proteger, Detectar, Responder, Recuperar. NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na

4) D — Implementar a solução correspondente: APT (Advanced Persistent Threat): governme. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): APT (Advanced Persistent Threat): government-backed — recursos enormes, target longo-prazo. As demais alternativas conf

5) B — Implementar a solução correspondente: Organized crime = dinheiro; hacktivist = i. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Organized crime = dinheiro; hacktivist = ideologia; nation-state = política/militar. As demais alternativas configuram

6) C — Implementar a solução correspondente: Script kiddie: usa exploit pronto — volume. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Script kiddie: usa exploit pronto — volume, pouca sofisticação. As demais alternativas configuram violações graves de c

7) A — Implementar a solução correspondente: Insider: o maior risco por já estar DENTRO. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Insider: o maior risco por já estar DENTRO da confiança. As demais alternativas configuram violações graves de conformi

8) A — Implementar a solução correspondente: 'motivated by political/social ideology' =. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): 'motivated by political/social ideology' = hacktivist. As demais alternativas configuram violações graves de conformida

9) D — Implementar a solução correspondente: 'long-term, nation-state, persistent' = AP. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): 'long-term, nation-state, persistent' = APT. As demais alternativas configuram violações graves de conformidade ou falh

10) D — Implementar a solução correspondente: Cenário típico: 'um grupo financiado por g. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.1 (Threat Actors): Cenário típico: 'um grupo financiado por governo espiona infra-critical por meses' = APT (nation-state) — não hacktivis

